

Cybersecurity Audit Report

[CLIENT]

Prepared by: Jake Burleson

Audit Date: April 25, 2026

Framework: CMMC Level 1 (reframed for client NPI)

1. What We Did

This engagement was a one-time cybersecurity audit of [CLIENT], a small investment firm operating from a single office. The audit was conducted on-site on April 25, 2026, beginning at 12:35 PM and concluding at 1:45 PM. Principal served as the point of contact and made staff and systems available for inspection during the engagement.

The audit followed the procedure documented in the approved audit plan (attached) and consisted of four phases: (1) an unannounced arrival to gauge staff response to an unfamiliar individual entering the workspace, (2) a formal introduction to the Principal, (3) a working audit meeting in which the auditor walked through each control with the Principal and any relevant staff, and (4) a post-audit hot wash to convey initial findings.

The audit framework used was CMMC Level 1 (FAR 52.204-21 / NIST SP 800-171A), reframed to address the protection of client nonpublic personal information (NPI) and confidential financial data rather than Federal Contract Information. This framework was selected because, while the firm is not a defense contractor, the fifteen CMMC Level 1 practices map cleanly to the safeguarding obligations applicable to a registered investment firm under SEC Regulation S-P and the FTC Safeguards Rule. The full set of test conditions, expected findings, and pass/fail determinations is documented in the completed audit plan attached to this report.

Scope of the audit included the firm's Internet connection, end-user computing devices, mobile devices, network infrastructure, file storage, email, line-of-business applications used to access client data, the physical office environment, and the data-handling processes performed by firm personnel. The audit relied on visual inspection, configuration review, and interview-based attestation by the Principal; technical testing such as vulnerability scanning, penetration testing, and password cracking was out of scope.

2. Results

Of the fifteen CMMC Level 1 controls assessed, twelve passed and three failed. Detailed observations and pass/fail determinations for every control are documented in the completed audit plan attached to this report. The results are summarized below.

Overall, the firm's security posture is generally healthy. Strong technical controls are already in place: multi-factor authentication is enabled across all systems that touch client data, password complexity is enforced at twelve characters with symbols and numbers, workstations auto-lock after fifteen minutes, the wireless network is WPA3-protected with guest Wi-Fi isolated from firm systems, the firewall is professionally managed by a third-party IT firm, Microsoft Defender is deployed and auto-updating on every workstation, and weekly full scans run on schedule. Physical controls are also reasonable: network equipment is locked, exterior doors are secured when the office is unoccupied, and visitors are escorted. The failures and residual risks identified below should be read against that generally healthy baseline.

2.1 Summary of Pass/Fail Outcomes

Outcome	Count
Controls passed	12 of 15

Controls failed	3 of 15
-----------------	---------

2.2 Top Five Findings

The findings below are ranked by severity and risk to the firm and its clients. "Pass*" denotes a control that passed against its stated criteria but where the auditor identified a residual risk worth bringing to the Principal's attention. Full observations are recorded in the completed audit plan.

Rank	Audit Plan Item	Control	Severity	Finding Summary
1	Item 12 (Fail)	SI.L1-B.1.XII	High	No mechanism exists for staff to report suspected security issues (suspicious emails, malware, lost devices) to the Principal.
2	Item 7 (Fail)	MP.L1-B.1.VII	Medium	No documented procedure for sanitizing or destroying hard drives or other electronic media containing client data prior to disposal.
3	Item 1 (Fail)	AC.L1-B.1.I	Medium	A user roster exists, but no inventory of authorized devices (workstations, laptops, mobile devices) is maintained.
4	Item 2 (Pass*)	AC.L1-B.1.II	Low	Only the Principal has access to client records. The control passes on least-privilege grounds, but creates a key-person dependency and business continuity risk.
5	Item 9 (Pass*)	PE.L1-B.1.IX	Low	Visitors are escorted and keys are inventoried, but no visitor sign-in log is maintained. Acceptable given firm size, but represents a residual gap if the firm grows.

Finding 1 — No Mechanism for Staff to Report Suspected Security Issues (Item 12, SI.L1-B.1.XII)

Severity: High. Patch management itself was acceptable — auto-update is enabled, software is within vendor support — but the SI.L1-B.1.XII control also requires that staff be able to report suspected information system flaws in a timely manner. No such reporting path exists today. If a staff member receives a phishing email, notices unusual workstation behavior, or loses a phone, there is no defined channel, contact, or expected timeframe for escalation. Phishing is the leading attack vector against small investment firms, and a successful phish that goes unreported can sit silent in an inbox for hours or days while attackers establish persistence or stage wire fraud. The likelihood of a phishing attempt is high; the absence of a reporting channel materially increases the consequence of one succeeding.

Finding 2 — No Drive Sanitization or Destruction Procedure (Item 7, MP.L1-B.1.VII)

Severity: Medium. Paper records are appropriately handled with an in-office shredder, but no procedure exists for sanitizing or destroying electronic media at end of life. This includes the hard drives in retired workstations, laptops, USB drives used for backups or transfers, and the internal storage of multi-function printers and copiers. A drive disposed of without sanitization may retain years of client NPI — Social Security numbers, account numbers, statements, tax documents — recoverable by anyone who acquires the device. The likelihood is low (drives are disposed of infrequently), but the consequence per incident is severe.

Finding 3 — No Device Inventory (Item 1, AC.L1-B.1.I)

Severity: Medium. The firm maintains a current roster of authorized users and only those users hold active accounts, which satisfies the access-control half of this requirement. However, no inventory of authorized devices exists. The firm cannot readily answer the question "what computers, laptops, phones, and tablets are permitted to access our systems and our client data?" Without that inventory, it is difficult to detect an unauthorized device, to confirm that every endpoint has anti-malware and current patches applied, or to ensure a device is wiped and recovered when an employee departs. This is a foundational hygiene gap rather than an immediate threat, but it is the gap that quietly enables others.

Finding 4 — Single-Person Access to Client Records (Item 2, AC.L1-B.1.II — Pass*)

Severity: Low. This control passed on its stated criteria: access to client records is restricted strictly to the Principal, which is the strongest possible application of least privilege. However, this configuration creates a key-person dependency. If the Principal is unavailable due to illness, travel, or any unexpected event, the firm has no documented or technical means for another individual, even a designated successor, to retrieve client records to service clients or meet regulatory obligations. This is a business continuity finding rather than a confidentiality finding, but it belongs in this report because cybersecurity and operational resilience overlap on questions of availability.

Finding 5 — No Visitor Sign-In Log (Item 9, PE.L1-B.1.IX — Pass*)

Severity: Low. The control passed because visitors are escorted, keys are inventoried, and the firm's small size justifies the absence of a formal log. This is a defensible position today. The residual risk is that, in the event of a future incident, a suspected data theft, a missing document, an after-hours intrusion, the firm has no record of who was on premises and when. The cost of starting a simple log is essentially zero, and it preserves an evidentiary trail that becomes valuable only when something goes wrong.

3. Recommendations

The recommendations below are presented in priority order, matching the ranking of findings in Section 2. Each recommendation is scoped to be implementable by a small firm with limited IT staff, at minimal cost, and with negligible disruption to client-facing operations. None of the recommendations requires new hardware, network re-architecture, or software licensing beyond what the firm likely already owns.

Recommendation 1 — Stand Up an Incident-Reporting Procedure (Addresses Finding 1)

Write a one-page document that names the Principal as the firm's security point of contact and instructs staff to forward any suspicious email, unusual workstation behavior, lost device, or other security concern to him within one business day, with same-day reporting expected for anything actively in progress (e.g., a click on a phishing link). Include a short list of "red flags": unexpected attachments,

urgent wire requests, password reset emails the user did not initiate, unfamiliar pop-ups, so staff have concrete signals to watch for. Walk through the document with staff once, then revisit it annually.

Implementation cost is zero. Implementation impact on operations is a one-time thirty-minute conversation. Recommended timeline: within 30 days. This is the single highest-value action the firm can take and should be addressed first.

Recommendation 2 — Adopt a Drive Sanitization and Disposal Procedure (Addresses Finding 2)

Add a written procedure stating that any electronic media leaving firm custody must be either (a) physically destroyed or (b) sanitized using a documented multi-pass wipe that meets NIST SP 800-88 standards. For drives the firm cannot wipe in-house, a certified IT asset disposal vendor will provide a certificate of destruction for roughly \$10–\$20 per drive. The firm's existing third-party IT provider almost certainly offers this service or can recommend a vendor.

Implementation cost is negligible because drive disposal is infrequent for a firm this size. Recommended timeline: written procedure within 60 days, applied at the next disposal event. No impact on daily operations.

Recommendation 3 — Build a Device Inventory (Addresses Finding 3)

A simple spreadsheet is sufficient. Track, for each device that touches firm data: device type, model, serial number or asset tag, assigned user, operating system version, anti-malware status, and date last verified. Conduct an initial walk-around of the office to populate it (likely under an hour for a 2–5 person firm), then update it whenever a device is added, replaced, or retired. Review it annually against actual devices in use to detect drift.

Implementation cost is zero. Implementation impact on operations is roughly one hour up front and a few minutes per change thereafter. Recommended timeline: within 60 days, with annual review. This recommendation also makes Recommendations 1 and 2 easier to execute, since it provides the underlying list of assets they apply to.

Recommendation 4 — Document a Continuity-of-Access Plan (Addresses Finding 4)

Without compromising least-privilege, the Principal should ensure that critical credentials and instructions for accessing client records are recoverable by a designated trusted individual in the event the Principal is unavailable. The simplest implementation is a reputable password manager (Bitwarden, 1Password, or similar) with an emergency-access feature, paired with a brief written instruction kept in a sealed envelope or with the firm's attorney. The designated individual gains access only after a defined waiting period or upon a documented triggering event.

Implementation cost is \$0 (Bitwarden free tier supports emergency access) to roughly \$50 per year for a paid tier. Implementation impact on operations is one-time setup plus annual review of the emergency contact. Recommended timeline: within 90 days. This recommendation strengthens the firm's regulatory posture under SEC business continuity expectations as well.

Recommendation 5 — Start a Visitor Sign-In Log (Addresses Finding 5)

A standard paper logbook at reception is sufficient. Capture name, organization, time in, time out, and host. Clients may be exempted at the Principal's discretion; the value of the log is primarily in tracking vendors, repair personnel, and other non-client visitors. The log should be retained for at least one year.

Implementation cost is approximately \$10 for a logbook. Implementation impact on operations is a few seconds per visitor. Recommended timeline: within 30 days.

3.1 Consolidated Timeline

#	Recommended Action	Recommended Timeline	Estimated Cost
1	Establish a written incident-reporting procedure and a single point of contact for staff to report suspected security issues.	Within 30 days	\$0 (internal)
2	Adopt a written drive sanitization and disposal procedure; arrange for certified destruction at end of life.	Within 60 days	\$0 ongoing; ~\$10–\$20 per drive at disposal
3	Build and maintain a device inventory listing every workstation, laptop, phone, and tablet authorized to access firm data.	Within 60 days; reviewed annually	\$0 (spreadsheet)
4	Document a continuity-of-access plan so client records remain retrievable if the Principal is unavailable.	Within 90 days	\$0–\$50 for a password manager license, if not already in place
5	Begin a simple visitor sign-in log for non-staff visitors (clients excepted at the Principal's discretion).	Within 30 days	\$10 for a logbook

4. Risk Posture

[CLIENT]'s overall risk posture is moderate-to-low. The fundamentals that drive most real-world breaches against firms of this size are in place: MFA is enforced everywhere it matters, password and lockout policies are reasonable, the wireless and firewall environment is properly configured, endpoint anti-malware is deployed and updating, and physical controls over the office and network equipment are appropriate. None of the findings in this report indicate an active or imminent compromise.

That said, the firm is not well-positioned to detect or respond to an incident if one occurs, and the gaps that do exist concentrate in the areas of incident response, asset visibility, and operational resilience rather than in technical defenses.

4.1 Greatest Risk

The firm's greatest risk is targeted phishing. Investment firms are attractive targets specifically because their staff are trusted to authorize wire transfers and respond to client requests for funds. Threat actors are aware of this and craft convincing emails impersonating clients, the Principal, or known counterparties such as the firm's custodian. The firm's technical defenses (Gmail filtering, MFA, endpoint protection) reduce but do not eliminate this risk; well-crafted phishing routinely bypasses

email filters, and MFA can be defeated by a user who is socially engineered into approving a prompt. Phishing is the most likely cybersecurity event the firm will face in the next twelve months.

4.2 Greatest Vulnerability

The firm's greatest vulnerability is the absence of an incident-reporting and response mechanism (Finding 1). This is what converts the greatest risk into a likely loss. With strong technical defenses but no reporting channel, the firm depends entirely on prevention; once a phishing email reaches a user and persuades them to click, there is no defined path for that user to raise an alarm, no expected response time, and no playbook for the Principal to execute. The window between initial compromise and material loss in BEC cases is often measured in hours, and that window closes long before the firm would notice anything was wrong. Closing this vulnerability produces the largest single improvement in the firm's risk posture available from any of the recommendations in this report.

4.3 Conclusion

[CLIENT] has built a security program that, by the standards of small advisory firms, is well above average. The Principal has clearly invested in technical controls and engaged a third-party IT firm to manage the perimeter. The findings in this report should not be read as alarming, but as the next logical layer of maturity for a firm whose technical foundation is already sound: documented procedures, asset visibility, an incident-reporting channel, and operational resilience. With the five recommendations in Section 3 implemented over the next ninety days, the firm will be substantially better prepared to detect and respond to the cybersecurity threats most likely to be directed at a firm of its size and industry.